



DEVOIR D'ÉCOLE - 2024

COURS : SÉCURITÉ DES SYSTÈMES DE CONTRÔLE INDUSTRIEL

SUJET: TOKENS — SNORT — MITRE ATT&CK NAVIGATEUR — ZEEK
& RITA — SILK — "THREAT HUNTING" INVESTIGATION

FRÉDÉRIC PERRON



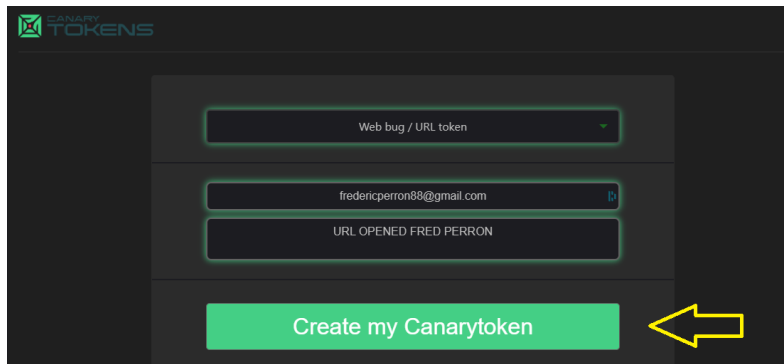
Table des Matières

Exercice No 1 – Tokens de Detection.....	1
Exercice No 2 - Règle Snort	5
Exercice No 3 (10p) – Navigateur MITRE ATT&CK	11
Exercice No 4 – Zeek & RITA	14
Exercice No 5 – SiLK	16
Exercice No 6 – Threat Hunting investigation. max 6 pages.....	20

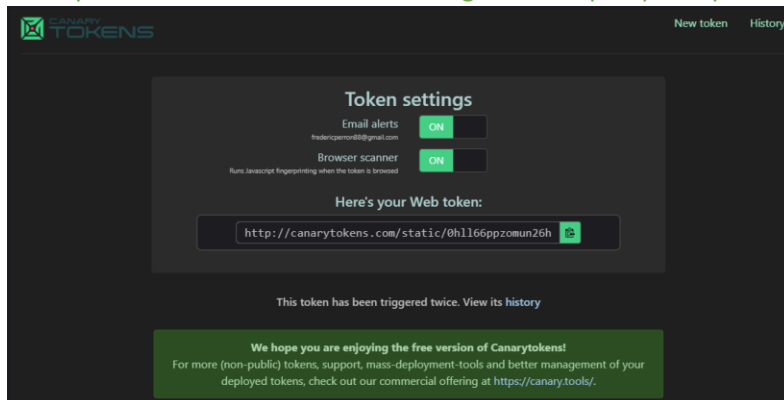
Exercice No 1 – Tokens de Detection (20p)

En utilisant le site web <https://canarytokens.org/generate> créez des scénarios et utilisez deux tokens différents. **Si possible, utilisez votre nom dans la solution choisie. Les points vont être donnés en fonction de la complexité de la solution choisie.**

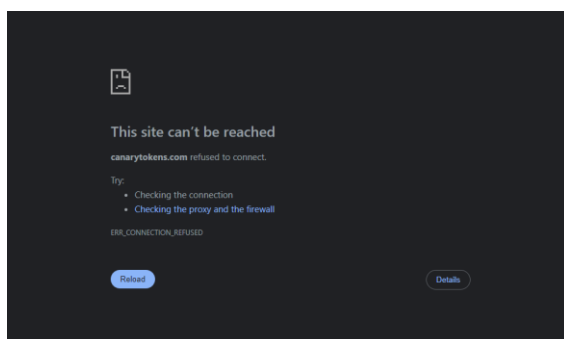
Premier scénario est très simple mais peut être extrêmement utile. Je vais commencer par créer un jeton avec l'option Web Bug URL.



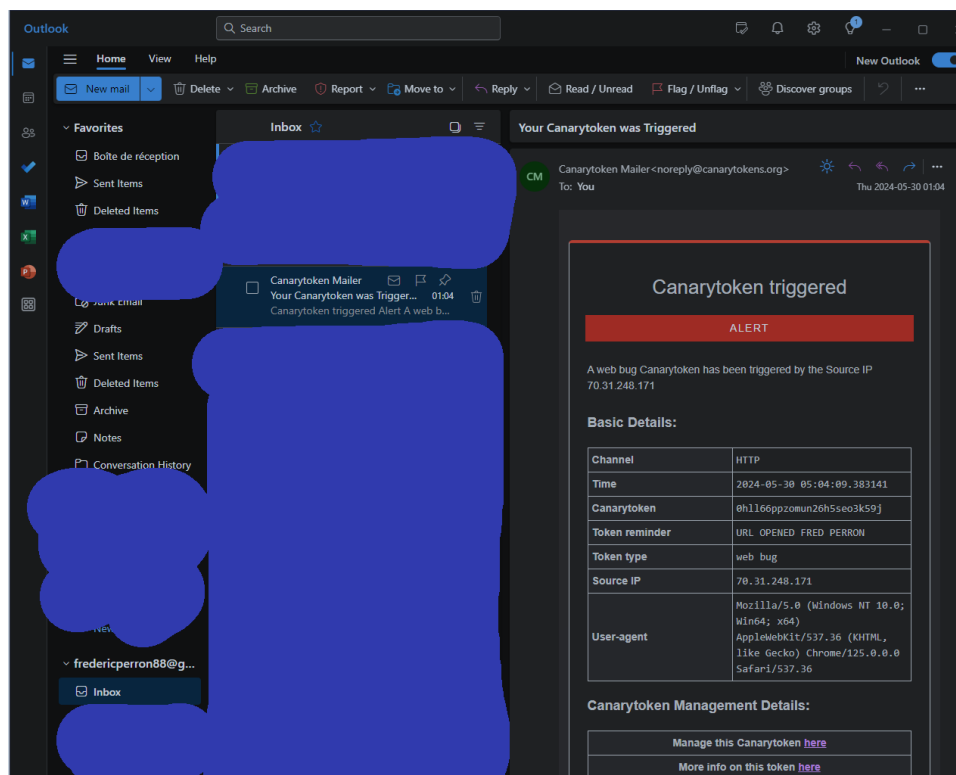
Nous pouvons ensuite voir le lien. Et également quelques options pour modifier des réglages.



Nous prenons ensuite ce lien, et le visitons dans une autre fenêtre. ***Attention*** Il faut remplacer le URL par .org au lieu de .com (sinon nous avons juste une page d'erreur de connexion. Voir image ci-dessous)



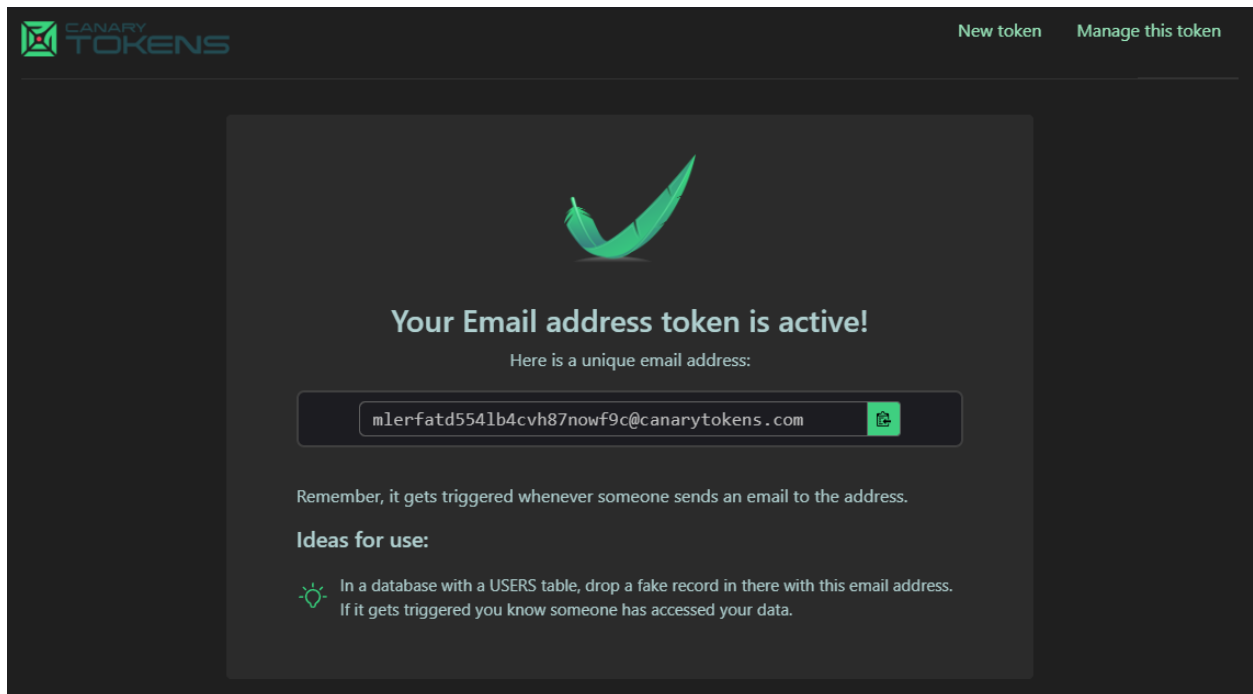
Lorsque nous modifier ce même URL par .org, nous avons finalement la blank page désirée. Et les alertes sont finalement déclenchées.



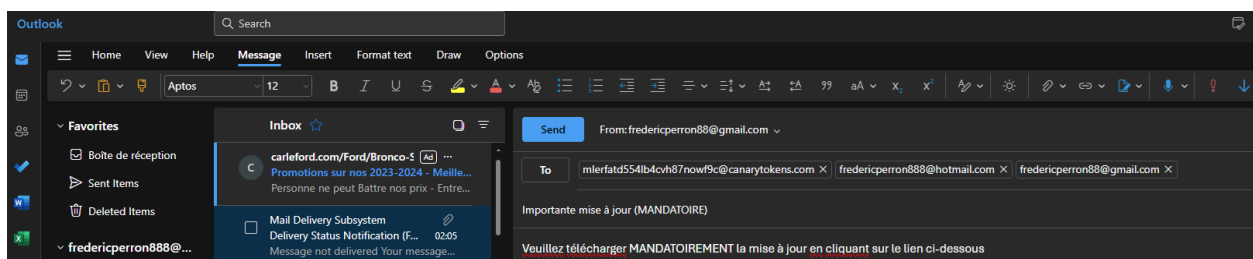
Le token Web Bug URL est un outil puissant de surveillance qui peut être utilisé dans une variété de scénarios de sécurité. Dans notre cas, où nous cherchons à détecter les tentatives d'accès non autorisées à un document sensible, le Web Bug URL offre une solution efficace. En intégrant ce lien de manière discrète dans des documents, des courriels ou d'autres canaux de communication, nous pouvons créer des leurres qui alertent immédiatement en cas d'activité suspecte.

Deuxième scénario est également simple. Nous allons simplement prendre un courriel temporaire donné par canarytokens et nous allons l'utiliser pour générer des alertes lorsque des courriels seront envoyés à cette même adresse.

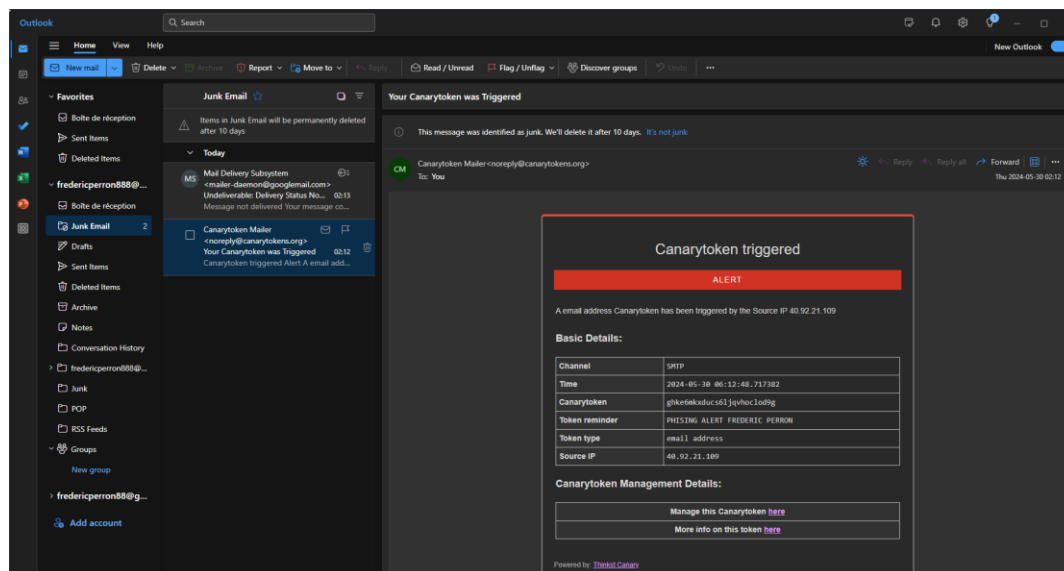
Nous commençons par générer le token sur canarytokens.org bien sûr :



Nous envoyons ensuite un courriel à partir de notre courriel ou n'importe lequel, pour voir si l'alerte va bel et bien trigger.



En attendant quelques minutes, nous recevons finalement l'alerte pour dire que le courriel a été rejoint. Voir image ci-dessous



Cela semble simple et banale, mais il y a une multitude de différentes utilisations possibles pour ce simple token. Voici 2 scénarios dans lequel ce simple token pourrait être extrêmement utile.

Détection des Fuites de Données Sensibles : En utilisant un courriel unique dans des documents, des bases de données ou des systèmes internes, une entreprise peut surveiller les tentatives de fuite de données sensibles. Toute communication non autorisée vers cette adresse peut déclencher une alerte, aidant ainsi à détecter les employés malveillants ou les comportements suspects.

Surveillance des Contacts avec des Partenaires Externes : Les entreprises peuvent utiliser des courriels uniques lors de la communication avec des partenaires externes, tels que des fournisseurs ou des clients. Cela leur permet de surveiller activement les interactions avec ces parties extérieures et de détecter tout comportement suspect ou non autorisé.

Exercice No 2 - Règle Snort (35p)

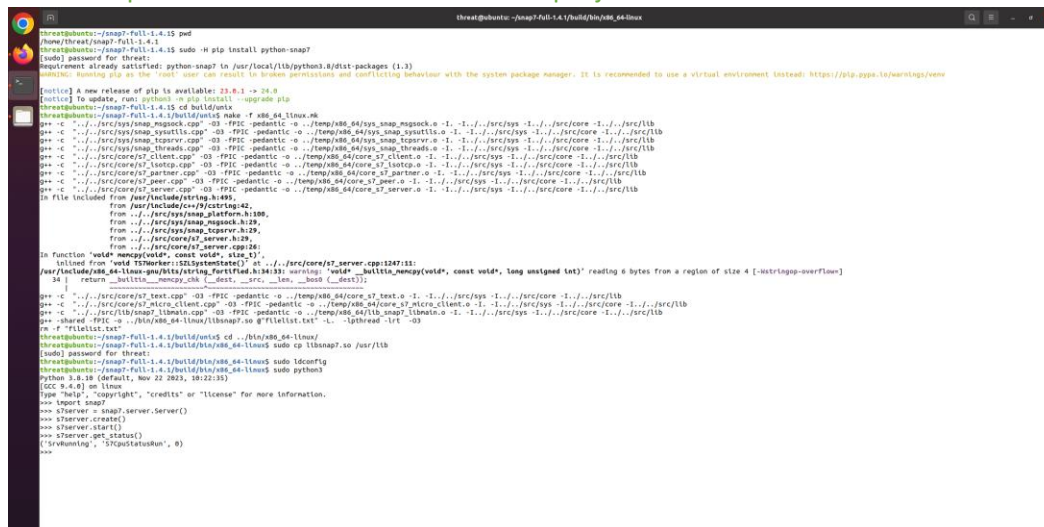
Scenario : vous êtes responsable de la sécurité dans une entreprise et vous devrez protéger les systèmes industrielles. Tous les systèmes industrielles sont dans un sous-réseau bien défini et seulement les postes d'ingénierie ont les droit de communiquer avec eux. Les systèmes d'ingénierie sont aussi dans une sous-réseau bien défini

A faire : Dans votre machine Hunting, écrivez une seule règle Snort qui va générer une alerte quand elle détecte une connexion vers un système industriel provenant d'une autre réseau que celui d'ingénierie. Implémentez la règle et la faire trigger.

Instructions

- Tout documenter avec des captures d'écran
- Créer un simulateur S7COMM (similaire au cours 3 Lab1 - Les attaques sur le protocole S7COMM qui va écouter sur le port 102) (2.5p)

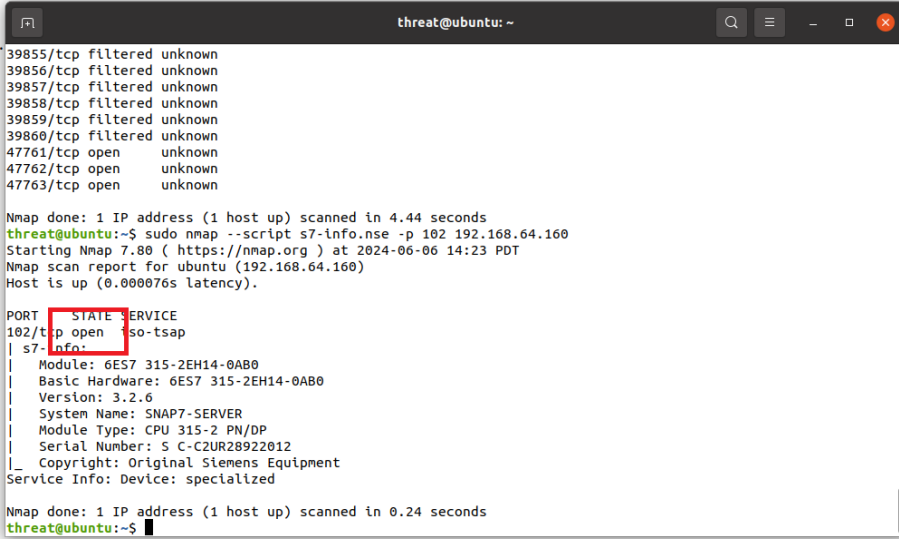
Voici la capture d'écran de mon terminal lorsque j'ai créé le serveur S7COMM



Lorsqu'il est en marche, on peut voir qu'il écoute bel et bien sur le port 102. *Voir image ci-dessous*

```
, const void*, long unsigned int)' reading 6 bytes from a region of size 4 [-Wstringop-overflow=]
```

```
../src/sys
ient.o -I.
-I. -I../
```



```
39855/tcp filtered unknown
39856/tcp filtered unknown
39857/tcp filtered unknown
39858/tcp filtered unknown
39859/tcp filtered unknown
39860/tcp filtered unknown
47761/tcp open unknown
47762/tcp open unknown
47763/tcp open unknown

Nmap done: 1 IP address (1 host up) scanned in 4.44 seconds
threat@ubuntu:~$ sudo nmap --script s7-info.nse -p 102 192.168.64.160
Starting Nmap 7.80 ( https://nmap.org ) at 2024-06-06 14:23 PDT
Nmap scan report for ubuntu (192.168.64.160)
Host is up (0.000076s latency).

PORT      STATE SERVICE
102/tcp   open  s7-tsap
| s7- info:
|   Module: 6ES7 315-2EH14-0AB0
|   Basic Hardware: 6ES7 315-2EH14-0AB0
|   Version: 3.2.6
|   System Name: SNAP7-SERVER
|   Module Type: CPU 315-2 PN/DP
|   Serial Number: S C-C2UR28922012
|_  Copyright: Original Siemens Equipment
Service Info: Device: specialized

Nmap done: 1 IP address (1 host up) scanned in 0.24 seconds
threat@ubuntu:~$
```

- c. Dans snort.conf définissez une nouvelle variable qui contient les IPs des systèmes industrielles, qui inclut l'IP de votre simulateur, (ex ICS_NET) (2.5p)

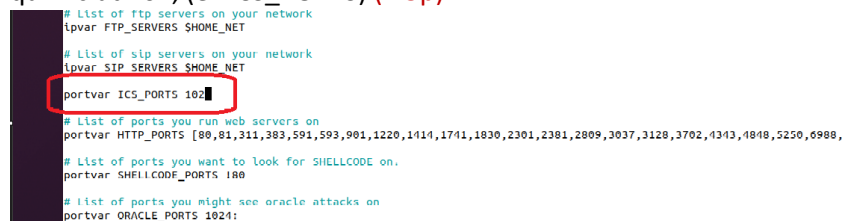
```
# Note to Debian users: this value is overridden when starting
# up the Snort daemon through the init.d script by the
# value of DEBIAN_SNORT_HOME_NET's defined in the
# /etc/snort/snort.debian.conf configuration file
#
# IP addresses:
#
# Set up the external network addresses. Leave as "any" in most situations
# If HOME_NET is defined as something other than "any", alternative, you can
# use this definition if you do not want to detect attacks from your internal
# IP addresses:
#
# List of DNS servers on your network
# List of SMTP servers on your network
# List of web servers on your network
# List of sql servers on your network
```



```
Ipvar HOME_NET any
Ipvar EXTERNAL_NET any
Ipvar ICS_NET 192.168.64.160
Ipvar DNS_SERVERS $HOME_NET
Ipvar SMTP_SERVERS $HOME_NET
Ipvar HTTP_SERVERS $HOME_NET
Ipvar SQL_SERVERS $HOME_NET
```

- d. Dans snort.conf définissez une nouvelle variable qui contient les ports de systèmes industrielles, qui inclut 102, (ex ICS_PORTS) (2.5p)

```
# List of ftp servers on your network
# List of sip servers on your network
# List of ports you run web servers on
# List of ports you want to look for SHELLCODE on.
# List of ports you might see oracle attacks on
```



```
portvar FTP_SERVERS $HOME_NET
portvar SIP_SERVERS $HOME_NET
portvar ICS_PORTS 102
portvar HTTP_PORTS [80,81,311,383,591,593,901,1220,1414,1741,1830,2301,2381,2809,3037,3128,3702,4343,4848,5250,6988,
portvar SHELLCODE_PORTS !80
portvar ORACLE_PORTS 1024;
```

- e. Dans snort.conf définissez une nouvelle variable qui contient les IPs des systèmes d'ingénierie autorisés à communiquer avec les systèmes industrielles (ex INGENIERIE_NET) (2.5p)


```
# Set up the external network addresses. Leave as "any" in most situations
ipvar EXTERNAL_NET any
# If HOME_NET is defined as something other than "any", alternative, you can
# use this definition if you do not want to detect attacks from your internal
# IP addresses:
ipvar EXTERNAL_NET !$HOME_NET
ipvar ICS_NET 192.168.64.160
ipvar INGENIERIE_NET 192.168.64.161

# List of DNS servers on your network
ipvar DNS_SERVERS $HOME_NET

# List of SMTP servers on your network
ipvar SMTP_SERVERS $HOME_NET

# List of web servers on your network
ipvar HTTP_SERVERS $HOME_NET

# List of sql servers on your network
ipvar SQL_SERVERS $HOME_NET

# List of telnet servers on your network
```

- f. Créez **une seule règle** Snort qui va détecter
 - a. Trafic vers un système industriel (IP et Port via des variables) (5p)
 - b. Trafic provenant d'un système autre que le systèmes d'ingénierie (via variables - ! devant une variable veut dire NOT) (5p)
 - c. Dans l'alerte, le message doit contenir votre nom / prénom (5p)

```
#!/usr/bin/perl
use strict;
use warnings;

# Local rules
# This file intentionally does not come with signatures. Put your local
# additions here.
alert icmp any any -> $HOME_NET any (msg: "ICMP test"; sid:1000001; rev:1; classtype:icmp-event;)
alert tcp !$INGENIERIE_NET any -> $ICS_NET $ICS_PORTS (msg:"Alert: Traffic to ICS from non-engineering system - Frederic Perron"; sid:1000002; rev:1);
```

- g. Générez du trafic qui va faire trigger la règle et montrez que la règle a été frappée :

```
(kali@kali)-[~]
$ sudo hping3 -S -p 102 192.168.64.160 -a 192.168.64.155

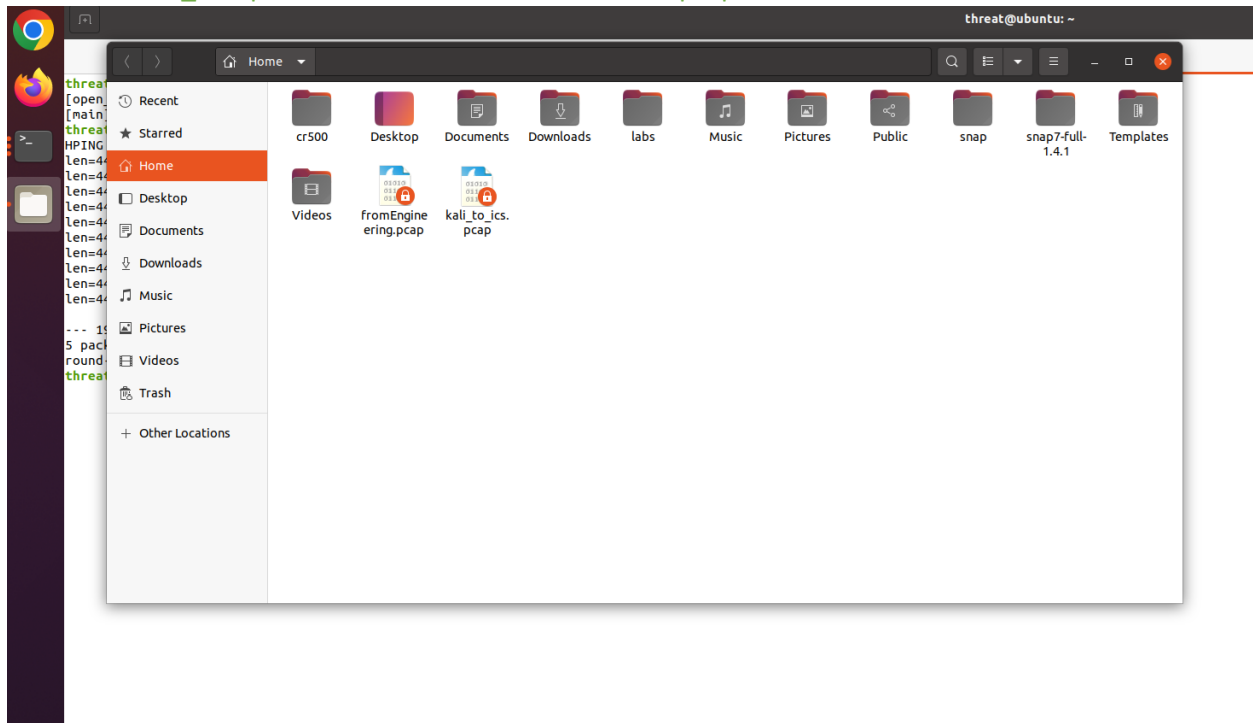
HPING 192.168.64.160 (eth0 192.168.64.160): S set, 40 headers + 0 data bytes
```

Et voici la preuve ci-dessous que la règle a trigger :

```
Preprocessor Object: SF_GTP Version 1.1 <Build 1>
Commencing packet processing (pid=54343)
06/06-23:11:27.419312 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] [TCP] 192.08.64.155:1624 -> 192.168.64.160:102
06/06-23:11:27.419579 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] [TCP] 192.08.64.155:1624 -> 192.168.64.160:102
06/06-23:11:28.420132 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] [TCP] 192.08.64.155:1625 -> 192.168.64.160:102
06/06-23:11:28.420372 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] [TCP] 192.08.64.155:1625 -> 192.168.64.160:102
06/06-23:11:29.421289 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] [TCP] 192.08.64.155:1626 -> 192.168.64.160:102
06/06-23:11:29.421490 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] [TCP] 192.08.64.155:1626 -> 192.168.64.160:102
06/06-23:11:30.422170 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] [TCP] 192.08.64.155:1627 -> 192.168.64.160:102
06/06-23:11:30.422374 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] [TCP] 192.08.64.155:1627 -> 192.168.64.160:102
06/06-23:11:31.423151 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] [TCP] 192.08.64.155:1628 -> 192.168.64.160:102
06/06-23:11:31.423354 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] [TCP] 192.08.64.155:1628 -> 192.168.64.160:102
06/06-23:11:32.424825 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] [TCP] 192.08.64.155:1629 -> 192.168.64.160:102
06/06-23:11:32.425020 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] [TCP] 192.08.64.155:1629 -> 192.168.64.160:102
06/06-23:11:33.425245 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] [TCP] 192.08.64.155:1630 -> 192.168.64.160:102
06/06-23:11:33.425449 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] [TCP] 192.08.64.155:1630 -> 192.168.64.160:102
06/06-23:11:34.425699 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] [TCP] 192.08.64.155:1631 -> 192.168.64.160:102
06/06-23:11:34.425922 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] [TCP] 192.08.64.155:1631 -> 192.168.64.160:102
06/06-23:11:35.109206 ** [1:1917:6] SCAN UHP service discover attempt ** [Classification: Detection of a Network Scan] [Priority: 3] [UDP] 192.168.64.162261 -> 239.255.255.250:1900
06/06-23:11:35.426147 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] [TCP] 192.08.64.155:1632 -> 192.168.64.160:102
06/06-23:11:35.426338 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] [TCP] 192.08.64.155:1632 -> 192.168.64.160:102
06/06-23:11:36.114194 ** [1:1917:6] SCAN UHP service discover attempt ** [Classification: Detection of a Network Scan] [Priority: 3] [UDP] 192.168.64.162261 -> 239.255.255.250:1900
```

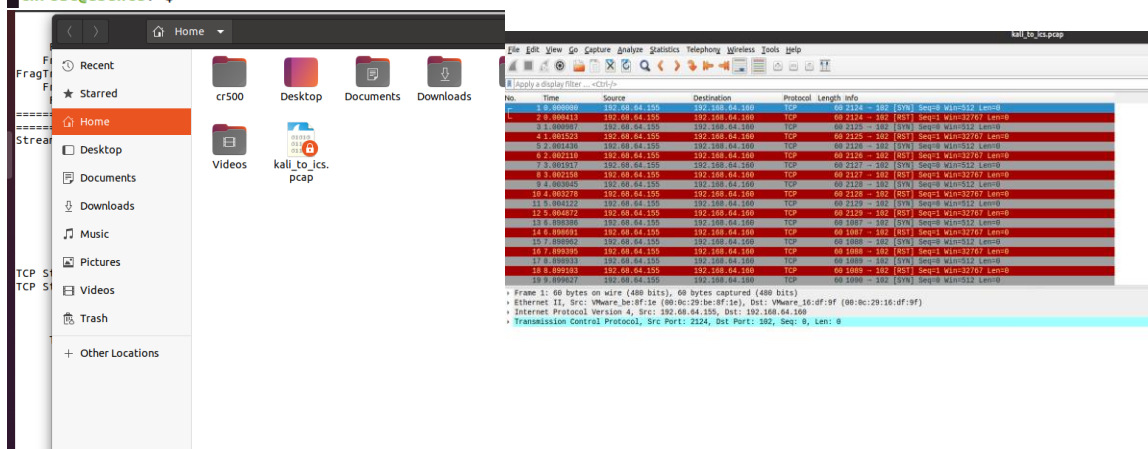
- a. Utilisez tcpdump avec filtre pour capturer seulement le trafic entre une source IP ingénierie – dest IP ICS et dest port ICS (2.5p)

J'ai fait le b. en premier. On fait un tcpdump comme ci-dessous à b mais avec un IP qui est dans la plage de INGENIERIE_NET pour finalement avoir nos 2 fichiers pcap.



- b. Utilisez tcpdump avec filtre pour capturer seulement le trafic entre une source IP autre qu'ingénierie – dest IP ICS et dest port ICS (2.5p)

```
threat@ubuntu:~$ sudo tcpdump -i ens33 src 192.68.64.155 and dst 192.168.64.160 and dst port 102 -w kali_to_ics.pcap
tcpdump: listening on ens33, link-type EN10MB (Ethernet), capture size 262144 bytes
^C34 packets captured
36 packets received by filter
0 packets dropped by kernel
threat@ubuntu:~$
```



- c. En utilisant les pcaps de deux points précédents testez votre règle (5p)

```

threat@ubuntu:~$ sudo snort -r /kall_to_tcs.pcap -c /etc/snort/snort.conf -A console
[sudo] password for threat:
Running in IDS mode

--== Initializing Snort ==--
Initializing Output Plugins!
Initializing Preprocessors!
Initializing Plug-Ins!
Parsing Rules File /etc/snort/snort.conf
Portvar 'ICL_PORTS' defined : [ 102 ]
Portvar 'HTTP_PORTS' defined : [ 80,81,110,143,311,383,591,593,901,1220,1434,1741,1830,2301,2381,2809,3037,3128,3702,4343,4848,5250,6988,7000,7001,7144,7145 ]
Portvar 'SHELLCODE_PORTS' defined : [ 0:79,81:5535 ]
Portvar 'ORACLE_PORTS' defined : [ 1024:65535 ]
Portvar 'SSH_PORTS' defined : [ 22 ]
Portvar 'FTP_PORTS' defined : [ 21,2300,3535 ]
Portvar 'SIP_PORTS' defined : [ 5060:5061,5080 ]
Portvar 'FILE_DATA_PORTS' defined : [ 0:80,81,110,143,311,383,591,593,901,1220,1434,1741,1830,2301,2381,2809,3037,3128,3702,4343,4848,5250,6988,7000:70 ]
Portvar 'ICL_PORTS' defined : [ 102 ]
Portvar 'ICL_PORTS' defined : [ 1024:65535 ]
Portvar 'FTP_PORTS' defined : [ 21,23,2152,3386 ]
Detection:
Search-Method = AC-Full-Q
Split Any/Any group = enabled
Search-Method-Optimizations = enabled
Minimum pattern length = 26
Tagged Packet Limit: 256
Loading dynamic engine /usr/lib/snort_dynamicengine/libsf_engine.so... done
Loading all dynamic detection libs from /usr/lib/snort_dynamicrules...
WARNING: No dynamic libraries found in directory /usr/lib/snort_dynamicrules.
Finished loading all dynamic detection libs from /usr/lib/snort_dynamicrules
Loading all dynamic preprocessor libraries from /usr/lib/snort_dynamicpreprocessor...
Loading dynamic preprocessor library /usr/lib/snort_dynamicpreprocessor/libsf_gtp_preproc.so... done
Loading dynamic preprocessor library /usr/lib/snort_dynamicpreprocessor/libsf_dns_preproc.so... done
Loading dynamic preprocessor library /usr/lib/snort_dynamicpreprocessor/libsf_smtp_preproc.so... done
Loading dynamic preprocessor library /usr/lib/snort_dynamicpreprocessor/libsf_dce2_preproc.so... done
Loading dynamic preprocessor library /usr/lib/snort_dynamicpreprocessor/libsf_slp_preproc.so... done
Loading dynamic preprocessor library /usr/lib/snort_dynamicpreprocessor/libsf_ftptelnet_preproc.so... done
Loading dynamic preprocessor library /usr/lib/snort_dynamicpreprocessor/libsf_dnp3_preproc.so... done
Loading dynamic preprocessor library /usr/lib/snort_dynamicpreprocessor/libsf_pop_preproc.so... done
Loading dynamic preprocessor library /usr/lib/snort_dynamicpreprocessor/libsf_lmtp_preproc.so... done
Loading dynamic preprocessor library /usr/lib/snort_dynamicpreprocessor/libsf_map_preproc.so... done
Loading dynamic preprocessor library /usr/lib/snort_dynamicpreprocessor/libsf_reputation_preproc.so... done
Loading dynamic preprocessor library /usr/lib/snort_dynamicpreprocessor/libsf_val_preproc.so... done
Loading dynamic preprocessor library /usr/lib/snort_dynamicpreprocessor/libsf_modbus_preproc.so... done

```

```

threat@ubuntu:~$
Copyright (c) 2014 Cisco and/or its affiliates. All rights reserved.
Copyright (c) 1998-2013 Sourcefire, Inc., et al.
Using libpcap version 1.9.1 (with PACKET_V3)
Using PDBE version: 8.39 2016-06-14
Using ZLIB version: 1.2.11

Rules Engine: SF_SNORT_DETECTION_ENGINE Version 2.4 <Build 1>
Preprocessor Object: SF_MQOBS Version 1.1 <Build 1>
Preprocessor Object: SF_SALPP Version 1.1 <Build 1>
Preprocessor Object: SF_REPUTATION Version 1.1 <Build 1>
Preprocessor Object: SF_SDF Version 1.1 <Build 1>
Preprocessor Object: SF_SSH Version 1.1 <Build 3>
Preprocessor Object: SF_INAP Version 1.0 <Build 1>
Preprocessor Object: SF_DNP3 Version 1.1 <Build 1>
Preprocessor Object: SF_FTPTELNET Version 1.2 <Build 13>
Preprocessor Object: SF_POP Version 1.0 <Build 1>
Preprocessor Object: SF_SIP Version 1.1 <Build 1>
Preprocessor Object: SF_DCEPC2 Version 1.0 <Build 3>
Preprocessor Object: SF_SMP Version 1.1 <Build 9>
Preprocessor Object: SF_DNS Version 1.1 <Build 4>
Preprocessor Object: SF_GTP Version 1.1 <Build 1>

Commencing packet processing (pid:57582)
06/06-23:19:47.788900 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:2124 -> 192.168.
06/06-23:19:47.789313 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:2124 -> 192.168.
06/06-23:19:48.789887 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:2125 -> 192.168.
06/06-23:19:48.790423 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:2125 -> 192.168.
06/06-23:19:49.790336 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:2126 -> 192.168.
06/06-23:19:49.791010 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:2126 -> 192.168.
06/06-23:19:50.790817 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:2127 -> 192.168.
06/06-23:19:50.791058 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:2127 -> 192.168.
06/06-23:19:51.791945 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:2128 -> 192.168.
06/06-23:19:51.792178 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:2128 -> 192.168.
06/06-23:19:52.793022 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:2129 -> 192.168.
06/06-23:19:52.793772 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:2129 -> 192.168.
06/06-23:19:54.087286 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:1087 -> 192.168.
06/06-23:19:54.087591 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:1087 -> 192.168.
06/06-23:19:55.087862 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:1088 -> 192.168.
06/06-23:19:55.088295 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:1088 -> 192.168.
06/06-23:19:56.087833 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:1089 -> 192.168.
06/06-23:19:56.088003 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:1089 -> 192.168.
06/06-23:19:57.088527 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:1090 -> 192.168.
06/06-23:19:57.088719 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:1090 -> 192.168.
06/06-23:19:58.089483 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:1091 -> 192.168.
06/06-23:19:58.089766 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:1091 -> 192.168.
06/06-23:19:59.089762 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:1092 -> 192.168.
06/06-23:19:59.089960 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:1092 -> 192.168.
06/06-23:20:00.090720 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:1093 -> 192.168.
06/06-23:20:00.090927 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:1093 -> 192.168.
06/06-23:20:01.091049 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:1094 -> 192.168.
06/06-23:20:01.091211 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:1094 -> 192.168.
06/06-23:20:02.091826 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:1095 -> 192.168.
06/06-23:20:02.091978 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:1095 -> 192.168.
06/06-23:20:03.093456 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:1096 -> 192.168.
06/06-23:20:03.093714 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:1096 -> 192.168.
06/06-23:20:04.094661 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:1097 -> 192.168.
06/06-23:20:04.095020 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.68.64.155:1097 -> 192.168.

Run time for packet processing was 1.1794 seconds
Snort processed 34 packets.
Snort ran for 0 days 0 hours 0 minutes 1 seconds
Pkts/sec: 34
=====
Memory usage summary:
Total non-mapped bytes (arena): 43860160
Bytes in named reontions (rbhlkhd): 11574144

```

Et maintenant le fichier fromEngineering.pcap :

```
SMTP Preprocessor Statistics
Total sessions : 0
Max concurrent sessions : 0
=====
dcerpc2 Preprocessor Statistics
Total sessions: 0
=====
SIP Preprocessor Statistics
Total sessions: 0
=====
Snort exiting
threat@ubuntu:~$ sudo snort -r fromEngineering.pcap -c /etc/snort/snort.conf -A console
Running in IDS mode

--== Initializing Snort ==--
Initializing Output Plugins!
Initializing Preprocessors!
Initializing Plug-ins!
Parsing Rules file "/etc/snort/snort.conf"
PortVar 'ICS_PORTS' defined : [ 102 ]
PortVar 'HTTP_PORTS' defined : [ 80:81 311 383 591 593 901 1220 1414 1741 1830 2301 2381 2809 3037 3128
88 8899 9000 9060 9080 9090:9091 9443 9999 11371 34443:34444 41080 50002 55555 ]
PortVar 'SHELLCODE_PORTS' defined : [ 0:79 81:65535 ]
PortVar 'ORACLE_PORTS' defined : [ 1024:65535 ]
PortVar 'SSH_PORTS' defined : [ 22 ]
PortVar 'FTP_PORTS' defined : [ 21 2100 3535 ]
PortVar 'SIP_PORTS' defined : [ 5060:5061 5600 ]
PortVar 'FILE_DATA_PORTS' defined : [ 80:81 110 143 311 383 591 593 901 1220 1414 1741 1830 2301 2381 28
8300 8800 8888 8899 9000 9060 9080 9090:9091 9443 9999 11371 34443:34444 41080 50002 55555 ]
PortVar 'GTP_PORTS' defined : [ 2123 2152 3386 ]
Detection:
Search-Method = AC-Full-Q
Split Any/Any group = enabled
Search-Method-Optimizations = enabled
Maximum pattern length = 20
Tagged Packet Limit: 256
Loading dynamic engine /usr/lib/snort_dynamicengine/libsfs_engine.so... done
Loading all dynamic detection libs from /usr/lib/snort_dynamicrules...
```

Et la règle a également trigger :

```
Copyright (C) 2014 Cisco and/or its affiliates. All rights reserved.
Copyright (C) 1998-2013 Sourcefire, Inc., et al.
Using libpcap version 1.9.1 (with TP_PACKET_V3)
Using PCRE version: 8.39 2016-06-14
Using ZLIB version: 1.2.11

Rules Engine: SF_SNORT_DETECTION_ENGINE Version 2.4 <Build 1>
Preprocessor Object: SF_MODBUS Version 1.1 <Build 1>
Preprocessor Object: SF_SSHPP Version 1.1 <Build 4>
Preprocessor Object: SF_REPUTATION Version 1.1 <Build 1>
Preprocessor Object: SF_SDF Version 1.1 <Build 1>
Preprocessor Object: SF_SSA Version 1.1 <Build 3>
Preprocessor Object: SF_INAP Version 1.0 <Build 1>
Preprocessor Object: SF_POP Version 1.0 <Build 1>
Preprocessor Object: SF_DWP3 Version 1.1 <Build 1>
Preprocessor Object: SF_FTPTELNET Version 1.2 <Build 13>
Preprocessor Object: SF_SIP Version 1.1 <Build 1>
Preprocessor Object: SF_DICERPC2 Version 1.0 <Build 3>
Preprocessor Object: SF_SMTP Version 1.1 <Build 9>
Preprocessor Object: SF_DNS Version 1.1 <Build 4>
Preprocessor Object: SF_GTP Version 1.1 <Build 1>

Commencing packet processing (pid=58901)
06/06-23:19:47.788900 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:2124 -> 192.168.04.160:102
06/06-23:19:47.789313 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:2124 -> 192.168.04.160:102
06/06-23:19:48.790887 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:2125 -> 192.168.04.160:102
06/06-23:19:48.790423 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:2125 -> 192.168.04.160:102
06/06-23:19:48.790336 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:2126 -> 192.168.04.160:102
06/06-23:19:49.791010 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:2126 -> 192.168.04.160:102
06/06-23:19:50.790817 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:2127 -> 192.168.04.160:102
06/06-23:19:50.791058 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:2127 -> 192.168.04.160:102
06/06-23:19:51.792178 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:2128 -> 192.168.04.160:102
06/06-23:19:52.793002 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:2129 -> 192.168.04.160:102
06/06-23:19:52.793772 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:2129 -> 192.168.04.160:102
06/06-23:19:54.687286 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:1087 -> 192.168.04.160:102
06/06-23:19:54.687591 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:1087 -> 192.168.04.160:102
06/06-23:19:55.687862 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:1088 -> 192.168.04.160:102
06/06-23:19:55.688295 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:1088 -> 192.168.04.160:102
06/06-23:19:56.687833 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:1089 -> 192.168.04.160:102
06/06-23:19:56.688003 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:1089 -> 192.168.04.160:102
06/06-23:19:57.688527 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:1090 -> 192.168.04.160:102
06/06-23:19:57.688719 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:1090 -> 192.168.04.160:102
06/06-23:19:58.689483 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:1091 -> 192.168.04.160:102
06/06-23:19:58.689796 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:1091 -> 192.168.04.160:102
06/06-23:19:59.689762 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:1092 -> 192.168.04.160:102
06/06-23:19:59.689966 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:1092 -> 192.168.04.160:102
06/06-23:20:00.690726 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:1093 -> 192.168.04.160:102
06/06-23:20:00.690927 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:1093 -> 192.168.04.160:102
06/06-23:20:01.691049 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:1094 -> 192.168.04.160:102
06/06-23:20:01.691211 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:1094 -> 192.168.04.160:102
06/06-23:20:02.691026 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:1095 -> 192.168.04.160:102
06/06-23:20:02.691978 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:1095 -> 192.168.04.160:102
06/06-23:20:03.693456 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:1096 -> 192.168.04.160:102
06/06-23:20:03.693714 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:1096 -> 192.168.04.160:102
06/06-23:20:04.694601 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:1097 -> 192.168.04.160:102
06/06-23:20:04.695020 ** [1:1000002:1] Alert: Traffic to ICS from non-engineering system - Frederic Perron ** [Priority: 0] (TCP) 192.08.04.161:1097 -> 192.168.04.160:102
```

Terminé pour cet exercice (02).

Exercice No 3 (10p) – Navigateur MITRE ATT&CK

Vous travaillez pour Hydro-Québec et vous voulez identifier les différents auteurs de menaces qui sont actifs dans votre domaine. Vous évaluez chaque acteur par un score spécifique.

Naviguer à <https://mitre-attack.github.io/attack-navigator/> version ICS et effectuer les tâches suivantes :

- a) Combiner les groupes suivants, en donnant à chacun les points suivants (5p)
 - a. ALLANITE – 5 points
 - b. APT33 – 5 points
 - c. OilRig- 5 points
 - d. TEMP.Veles– 5 points
- b) Prendre une capture d'écran de vos résultats et la mettre dans le devoir. Exporter le fichier json lié à la nouvelle couche et le joindre au devoir (2.5p)
- c) Trouver les 4 techniques ayant le score combiné le plus élevé (2.5p)

Nous commençons par créer les 4 couches pour pouvoir les combiner. Nous créons les 4 couches et nous leur attribuons un score de 5 points chaque. Voici un exemple de comment créer une couche (layer)

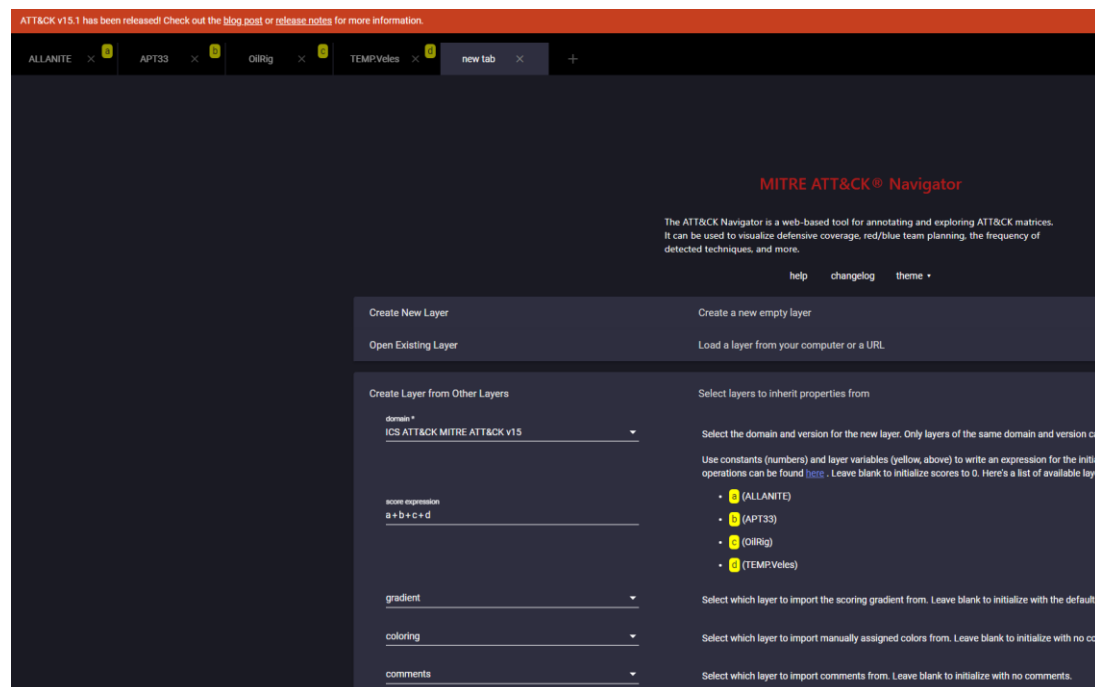
The first screenshot shows the MITRE ATT&CK Navigator interface. A red arrow points to the 'new tab' button in the top navigation bar. Another red arrow points to the 'Create New Layer' button in the 'Create New Layer' dialog box. The dialog box shows three options: 'Enterprise ATTACK', 'Mobile ATTACK', and 'ICS ATTACK'. The 'ICS ATTACK' option is selected.

The second screenshot shows the main interface of the MITRE ATT&CK Navigator. A red arrow points to the 'TEMP/Veles' layer in the top navigation bar. Another red arrow points to the 'Search' bar on the right side of the interface. The search bar contains the text 'name: ALLANITE OR description: APT33 OR data sources: OilRig'. A third red arrow points to the 'Threat Groups' section on the right side of the interface. The 'Threat Groups' section lists several groups: ALLANITE, APT33, APT38, CyberAr/ingers, and Dragonfly. The 'ALLANITE' group is selected.

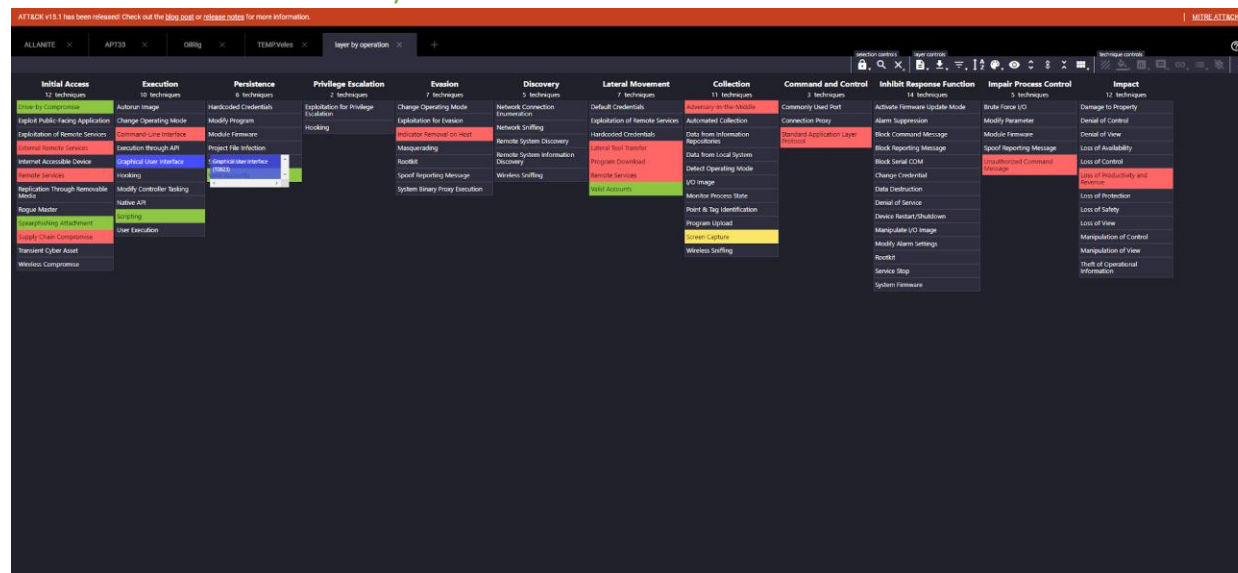
Annotations in the second screenshot include:

- Red text: "put the score 5 on each" (pointing to the 'select all' button for each threat group)
- Red text: "2 expand the threat groups window and select one of the four threat group listed in the homework" (pointing to the 'Threat Groups' section)
- Red text: "3" (pointing to the 'select all' button for the 'ALLANITE' group)

Une fois que nous avons nos 4 layers avec nos threat groups, c'est le temps de faire comme Cristian dans le cours 7 et les combiner en 1 layer.



Voici le résultat final de notre layer :



Lorsqu'on mouse over les techniques, nous pouvons voir le score pour cette même technique.

Résultats de l'Analyse des Techniques :

Après avoir combiné les groupes "ALLANITE", "APT33", "OilRig", et "TEMP.Veles" avec chacun 5 points, nous avons identifié les techniques ayant les scores combinés les plus élevés.

Techniques avec le Score Combiné le Plus Élevé :

Technique 1

T1189 - Drive-by Compromise

Description : Compromission d'un système via l'exploitation de vulnérabilités dans un navigateur web ou un plugin lors de la visite d'un site web malveillant ou compromis. Ce type d'attaque ne nécessite aucune action de l'utilisateur autre que de visiter le site web.

Technique 2

T1566.001 - Spearphishing Attachment

Description : Envoi de courriels ciblés avec des pièces jointes malveillantes conçues pour infecter le système de l'utilisateur lorsqu'elles sont ouvertes. Les pièces jointes peuvent contenir des macros, des exploits ou des scripts malveillants.

Technique 3

T1064 - Scripting

Description : Utilisation de scripts et d'interpréteurs de commandes pour exécuter des commandes malveillantes. Les scripts peuvent automatiser des tâches, injecter des charges utiles, ou contourner les mécanismes de sécurité en place.

Technique 4

T1078 - Valid Accounts

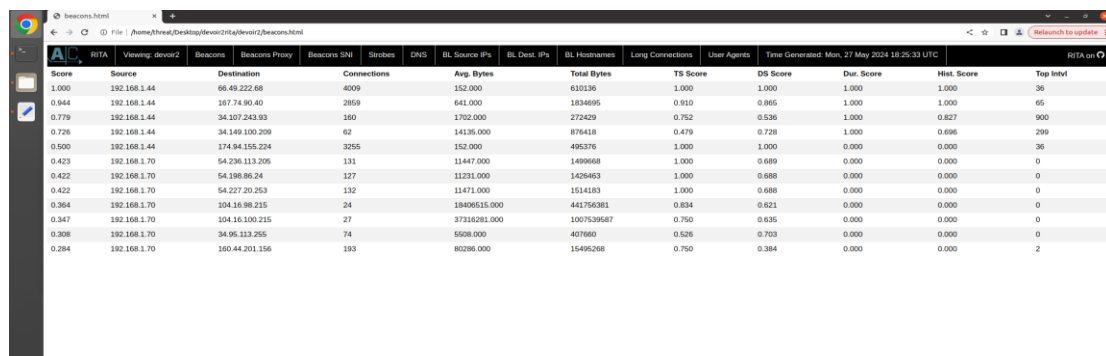
Description : Utilisation de comptes d'utilisateurs légitimes pour accéder aux systèmes et aux réseaux. Les attaquants peuvent obtenir ces comptes par des moyens tels que l'hameçonnage, le vol d'informations d'identification ou l'exploitation de faiblesses dans la gestion des comptes.

Puisque ces techniques partagent le même score maximal, il est important de les considérer toutes pour avoir une vue complète des menaces les plus pertinentes pour Hydro-Québec. Chacune de ces techniques représente des actions couramment utilisées par les groupes de menaces analysés, indiquant ainsi des vecteurs d'attaque prioritaires à surveiller et à sécuriser.

Exercice No 4 – Zeek & RITA (5p)

En utilisant les instructions du laboratoire 4 - cours 6, la machine Hunting et les fichiers dans le dossier devoir2rita faite une analyse de ces fichiers avec l’outil RITA

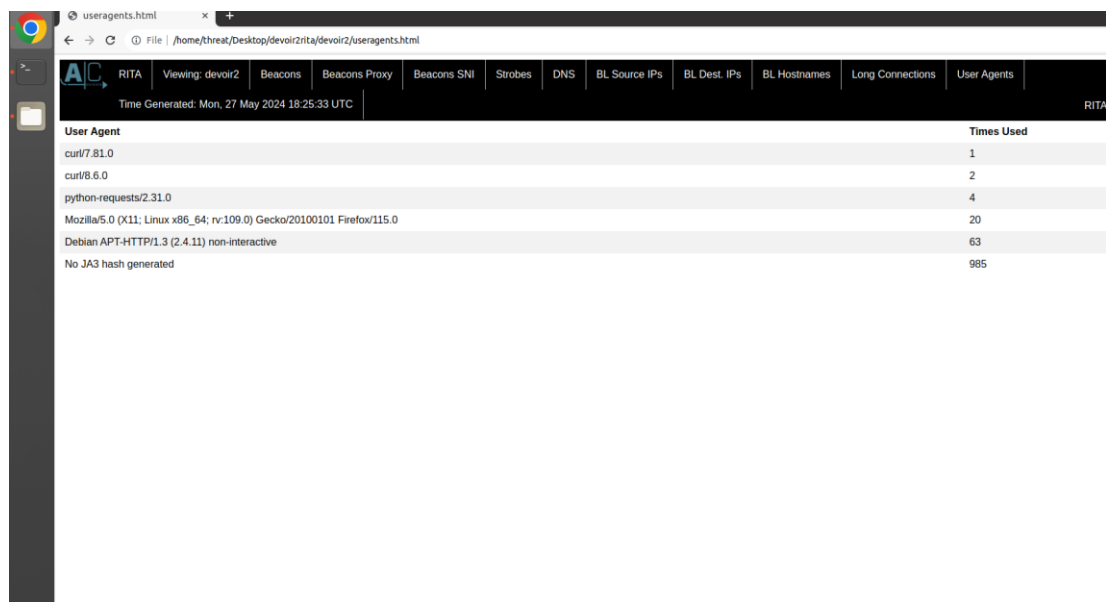
Nous commençons par extraire les fichiers html du devoir2 dans le desktop pour pouvoir y accéder depuis mon browser. Arrivé à la section beacons, voici les résultats et mon analyse de ceux-ci :



Score	Source	Destination	Connections	Avg. Bytes	Total Bytes	TS Score	DS Score	Dur. Score	Hist. Score	Top Intvl
1.000	192.168.1.44	66.49.222.68	4009	152.000	610136	1.000	1.000	1.000	1.000	36
0.944	192.168.1.44	167.74.90.40	2859	641.000	1834695	0.910	0.865	1.000	1.000	65
0.779	192.168.1.44	34.107.243.93	160	1702.000	272429	0.752	0.536	1.000	0.827	900
0.726	192.168.1.44	34.149.100.209	62	14135.000	876418	0.479	0.728	1.000	0.696	299
0.500	192.168.1.44	174.94.168.224	3255	152.000	496376	1.000	1.000	0.000	0.000	36
0.423	192.168.1.70	54.236.113.205	131	11447.000	1499668	1.000	0.689	0.000	0.000	0
0.422	192.168.1.70	54.198.86.24	127	11231.000	1426463	1.000	0.688	0.000	0.000	0
0.422	192.168.1.70	54.227.20.253	132	11471.000	1514183	1.000	0.688	0.000	0.000	0
0.364	192.168.1.70	104.16.98.215	24	1840615.000	441756381	0.834	0.621	0.000	0.000	0
0.347	192.168.1.70	104.16.100.215	27	37316281.000	1007539587	0.750	0.635	0.000	0.000	0
0.308	192.168.1.70	34.95.113.255	74	5508.000	407860	0.526	0.703	0.000	0.000	0
0.284	192.168.1.70	160.44.201.156	193	80296.000	15495268	0.750	0.384	0.000	0.000	2

On peut en déduire qu’il y a la 192.168.1.44 qui est très suspicieux. C’est là qu’une porte dérobée se reconnectera constamment pour recevoir les commandes d’un attaquant à un intervalle spécifique. Il faudrait donc investiguer cette adresse IP dû à leurs haut nombre de connections qui est anormal.

Nous pouvons également voir le nombre d’User Agent “No JA3 hash generated” qui a été utilisé 985 fois comparé à 63 pour la deuxième. Cela devrait sembler vraiment suspicieux aussi.



User Agent	Times Used
curl/7.81.0	1
curl/8.6.0	2
python-requests/2.31.0	4
Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0	20
Debian APT-HTTP/1.3 (2.4.11) non-interactive	63
No JA3 hash generated	985

Par la suite, nous pouvons investiguer les journaux à partir de zeek, en trouvant les domaines les plus utilisés dans cette même période. Il y a aussi les durées de certaines connexions sont élevées (Dur. Score de 1.000 pour certaines IPs), indiquant des connexions prolongées, typiques de sessions de C2 maintenues ouvertes pour le transfert de commandes ou de données.

[illegible][illegible]

Objectifs : Inspecter les données de flux trouvés dans le fichier **ex5abcd.silk** pour analyser le comportement du réseau.

- a) Description : Combien d'enregistrements de flux sont dans le fichier **ex5abcd.silk**?

Conseil : Utilisez la commande **rwfilter** pour lire le fichier **ex5abcd.silk** et inclure tous les numéros de protocole possibles en utilisant le commutateur de partitionnement **-proto=0-255** et spécifiez **--print-stat** pour imprimer les statistiques. L'utilisation de **-print-stat** est un commutateur de sortie. (3p) **75**

```
threat@ubuntu:~/Desktop/devoir2SILK$ rwfilter ex5abcd.silk --proto=0-255 --print-stat
Files      1. Read      75. Pass      75. Fail      0.
threat@ubuntu:~/Desktop/devoir2SILK$
```

- b) Description : Trouvez les deux enregistrements de flux associés aux adresses IP 209.85.227.106 et au port 1088, et répondez aux questions qui suivent après les indices et l'espace pour enregistrer la commande Silk utilisée.

Conseil : Utilisez la commande **rwfilter** et spécifiez les paramètres de partitionnement pour **--any-address** et **--aport**. Ces paramètres recherchent le trafic dans les deux sens dans les flux. N'oubliez pas de fournir le fichier d'entrée **ex5abcd.silk** pour la commande **rwfilter** à lire et n'oubliez pas d'utiliser un paramètre de sortie de **--pass=stdout** pour passer les flux extraits à la commande suivante pour transformer la sortie en sortie ASCII.

Conseil : Dirigez la sortie du **rwfilter** vers la commande **rwcut** pour convertir la sortie du format binaire **rwfilter** en ASCII et afficher tous les champs de flux.

```
threat@ubuntu:~/Desktop/devoir2SILK$ rwfilter ex5abcd.silk --any-address=209.85.227.106 --aport=1088 --pass=stdout | rwcut --fields=sip,dip,sport,dport,stime,proto,packets,bytes
sip|
10.0.3.15|
209.85.227.106| 1088| 80|2010/01/01T00:01:26.109| 6| 5| 731|
209.85.227.106| 10.0.3.15| 80| 1088|2010/01/01T00:01:26.169| 6| 3| 553|
threat@ubuntu:~/Desktop/devoir2SILK$
```

Enregistrer les commandes de SiLK utilisées :

- En examinant les enregistrements de flux, quelle IP pensez-vous être le client? Pourquoi? (Regardez les ports et les heures de début.) **10.0.3.15 est le client. L'heure de début du flux montre que la connexion a été initiée par `10.0.3.15` (00 :01 :26.109), suivi par une réponse de `209.85.227.106` (00 :01 :26.169), ce qui suggère que 10.0.3.15 a initié la connexion.**
- Quel est le serveur? Pourquoi? (Regardez les ports et les heures de début.) **209.85.227.106. Le port source utilisé est 80, qui est le port standard pour http, indiquant qu'il s'agit d'un serveur web répondant à une demande http. Port 1088 est également éphémère utilisé par le client pour recevoir la réponse du client**
- Quel protocole utilisent-ils tous les deux ? **TCP**

- Quel côté a fermé la connexion? Comment le savez-vous? (Regardez les flags pour trouver un qui contient un F pour FIN ou un R pour RST.) Les flags indiquent comment les paquets sont utilisés dans les échanges de connexion TCP. Côté qui a fermé la connexion est 10.0.3.15, puisque Le flag 'R' dans les flags de 10.0.3.15 indique que cette IP a envoyé un paquet de réinitialisation de connexion, ce qui ferme immédiatement la connexion. Le flag RST est utilisé
- Combien de paquets et d'octets 10.0.3.15 ont-ils envoyés? 5 paquets, 731 bytes (octets)
- Combien de temps le flux a-t-il duré lorsque 209.85.227.106 est l'IP source? (Regardez le colonne durée.) 11.163

```
threat@ubuntu:~/Desktop/devoir2$ rfilter ex5abcd.silk --any-address=209.85.227.106 --sport=1088 --pass=stdout | rwcut --fields=sip,dip,sport,dport,stime,proto,packets,bytes,flags,dur
sIP|dIP|sPort|dPort|stime|proto|packets|bytes|flags|duration|
209.85.227.106|10.0.3.15|1088|80|2010/01/01T00:01:26.109|6|5|731|SRPA|11.223|
209.85.227.106|10.0.3.15|80|1088|2010/01/01T00:01:26.169|6|3|553|S PA|11.163|
```

- Quel jour/mois/année ces flux ont-ils commencé et à quelle heure?
(Format=YYYY/MM/DDTHH où Y est l'année, M le mois numérique, D le jour, et H l'heure. Le T est le séparateur de la date et de l'heure) (8p) 2010/01/01T00:01:26.109

```
threat@ubuntu:~/Desktop/devoir2$ rfilter ex5abcd.silk --any-address=209.85.227.106 --sport=1088 --pass=stdout | rwcut --fields=sip,dip,sport,dport,stime,proto,packets,bytes,flags,dur
sIP|dIP|sPort|dPort|stime|proto|packets|bytes|flags|duration|
209.85.227.106|10.0.3.15|1088|80|2010/01/01T00:01:26.109|6|5|731|SRPA|11.223|
209.85.227.106|10.0.3.15|80|1088|2010/01/01T00:01:26.169|6|3|553|S PA|11.163|
```

- c) Description : Quels sont les cinq principaux expéditeurs (IP sources) d'octets de données?

Conseil : Utilisez la commande **rwstats** pour lire le fichier **ex5abcd.silk** et spécifier une sélection **--fields sip**, sortie pour **--bytes**, et **--count** de 5. (3p) Voir image ci-dessous pour les 5 adresses IP.

```
threat@ubuntu:~/Desktop/devoir2$ rwstats ex5abcd.silk --fields=sip --values=bytes --count=5
INPUT: 75 Records for 19 Bins and 281672 Total Bytes
OUTPUT: Top 5 Bins by Bytes
sIP|Bytes|NBytes|cumul_N|
192.168.56.52|95397|33.868116|33.868116|
64.236.114.1|87414|31.833969|64.902085|
10.0.4.15|22190|7.877957|72.780042|
192.168.56.50|19195|6.814664|79.594706|
10.0.3.15|18799|6.674075|86.268781|
```

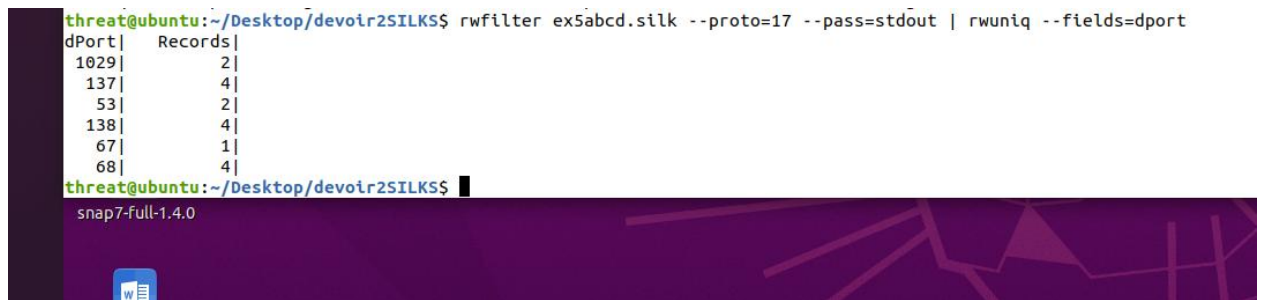


- d) Description : Quels sont tous les ports de destination UDP uniques?

Conseil : Utilisez la commande **rfilter** avec le fichier **ex5abcd.silk** pour extraire tous les flux UDP en utilisant un **-proto=17** comme un paramètre de partitionnement et passer les flux pour traitement ultérieur.

Conseil : Dirigez la sortie du **rfilter** vers la commande **rwuniq** pour afficher le port de destination trouvé dans **--fields=4** (le champ du port de destination) (3p) Voir image ci-dessous pour les 6 ports

```
threat@ubuntu:~/Desktop/devoir2SILKS$ rfilter ex5abcd.silk --proto=17 --pass=stdout | rwuniq --fields=dport
dPort|    Records|
1029|         2|
137|         4|
53|         2|
138|         4|
67|         1|
68|         4|
threat@ubuntu:~/Desktop/devoir2SILKS$
```



- e) En utilisant le fichier **ex5e.silk**, lancez une commande afin d'afficher le top 10 des regroupements par poids en Bytes (3p)

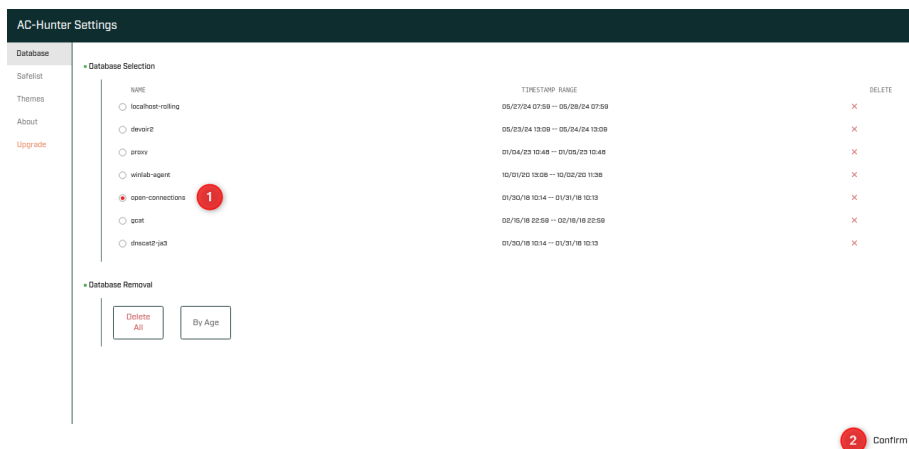
Voir image ci-dessous

```
threat@ubuntu:~/Desktop/devoir2SILKS$ rwstats --bytes --fields=bytes --count=10 ex5e.silk | sort -rn
411|         411|  7.539901| 84.149697|
264|        2376| 43.588332| 43.588332|
229|         229|  4.201064| 88.350761|
156|         156|  2.861860| 95.028435|
104|         208|  3.815814| 92.166575|
84|          84|  1.541002| 96.569437|
76|          76|  1.394240| 97.963676|
44|         440|  8.071913| 76.609796|
40|         800| 14.676206| 58.264539|
28|         560| 10.273344| 68.537883|
OUTPUT: Top 10 Bins by Bytes
INPUT: 68 Records for 12 Bins and 5451 Total Bytes
bytes|         Bytes|    %Bytes|  cumul_%|
threat@ubuntu:~/Desktop/devoir2SILKS$
```

Exercice No 6 – Threat Hunting investigation. max 6 pages (10p)

Objectifs – chercher des machines compromises. En utilisant la machine Hunting, dans Chrome connectez-vous à l'interface graphique d'AC Hunter - <https://127.0.0.1/home> . Changez la base de données

Et choisissez open-connections



Effectuez une analyse des différents indicateurs.

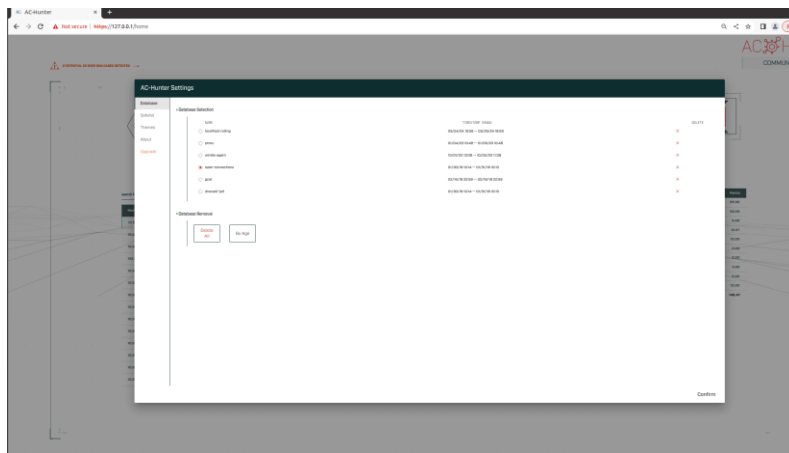


Utilise différentes fonctions d'AC Hunter : filter out an indicator, deep dive ...

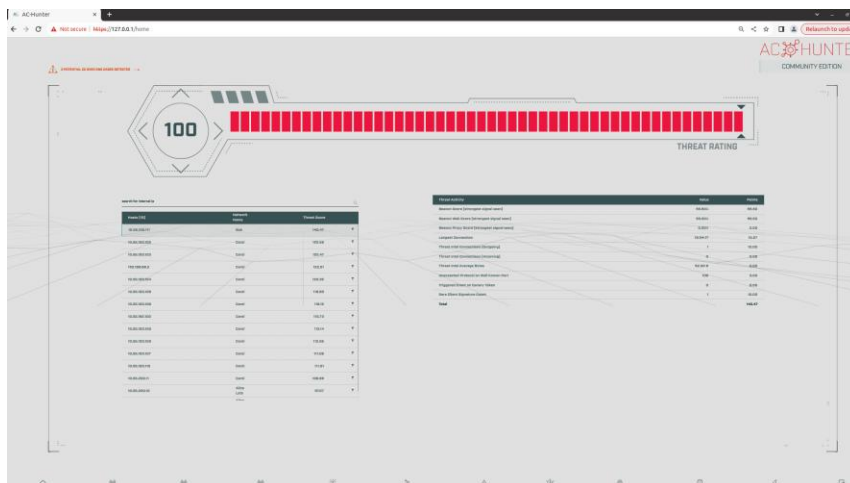
Utilisez comme modèle d'investigation <https://www.youtube.com/watch?v=of6KG3nfOFI>

La note va être donnée en fonction de la profondeur d'investigation

Nous commençons par choisir la base de données open-connections



Nous faisons ensuite confirm en bas a droite et lorsque nous retournons à la page principale, nous pouvons voir le nouveau Threat Rating de 100.



Nous pouvons constater qu'il y a quelques adresses IP avec un threat score élevé, mais une en particulier qui attire l'attention, la 10.55.100.111.

Nous pouvons constater ici qu'une seule machine a un nombre vraiment élevé de beacon connection count comparé aux autres. Voici ce que cela veut dire et ce qu'est un beacon/C2 attack :

Que Signifie 20 000 Connexions Beacon?

Avoir 20 000 connexions beacon signifie qu'il y a une activité de communication très fréquente et régulière entre l'adresse IP 10.55.100.111 et un serveur externe. Cela indique un comportement anormal et potentiellement malveillant, typique des communications entre un système compromis et un serveur de commande et contrôle (C2). Ce volume élevé de connexions suggère fortement que l'adresse IP est impliquée dans une activité de beaconing, où un malware ou un autre logiciel malveillant maintient une communication constante avec un serveur de commande et contrôle pour recevoir des instructions ou transmettre des données. Un score élevé de 20 000 connexions beacon pour l'adresse IP 10.55.100.111 est une indication claire d'une activité réseau suspecte, suggérant une communication régulière avec un serveur C2. Cela nécessite une investigation approfondie et une intervention immédiate pour isoler et

sécuriser le système compromis. En comprenant le fonctionnement des attaques de beacon et des serveurs C2, on peut mieux protéger les systèmes et les réseaux contre ces menaces persistantes.

Donc, en se fiant sur le nombre de connexion qu'on voit, on peut en déduire que cette adresse IP est probablement la machine compromise dont l'attaquant se sert pour communiquer avec les autres du réseau. Dans le schéma, nous pouvons voir 20,000 connexions en l'espace d'une seconde, suivi de 200-300 connexions par seconde. Qu'est-ce que cela peut signifier?

Communication Continue avec le Serveur C2 :

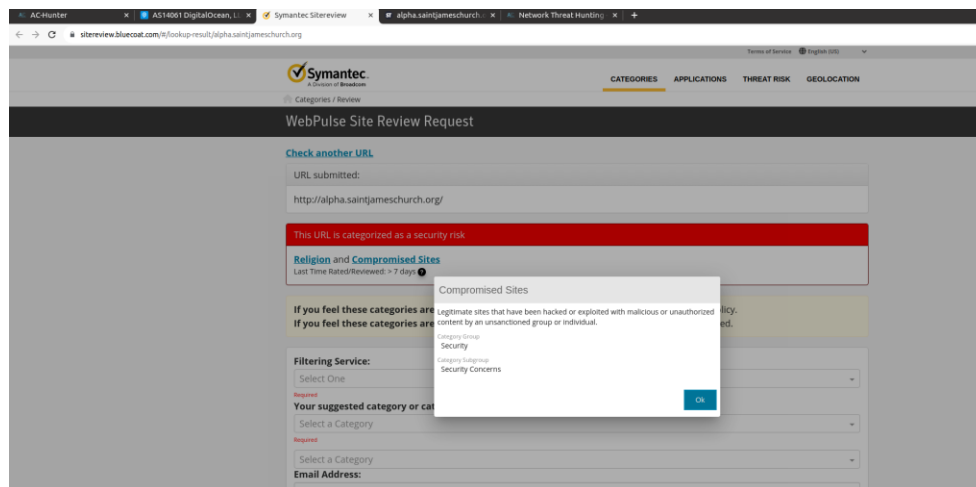
Explication : Après le pic initial, le schéma régulier de 200 à 300 connexions par seconde pourrait représenter une communication continue et stable avec le serveur C2. Le malware pourrait envoyer et recevoir des commandes, mettre à jour son statut, ou exfiltrer des données de manière constante.

Exfiltration ou Surveillance de Données :

Explication : Ce rythme soutenu de connexions pourrait également indiquer un processus d'exfiltration de données ou de surveillance continue. Le malware pourrait transmettre des données sensibles ou surveiller l'activité du réseau et rapporter ces informations au serveur C2.

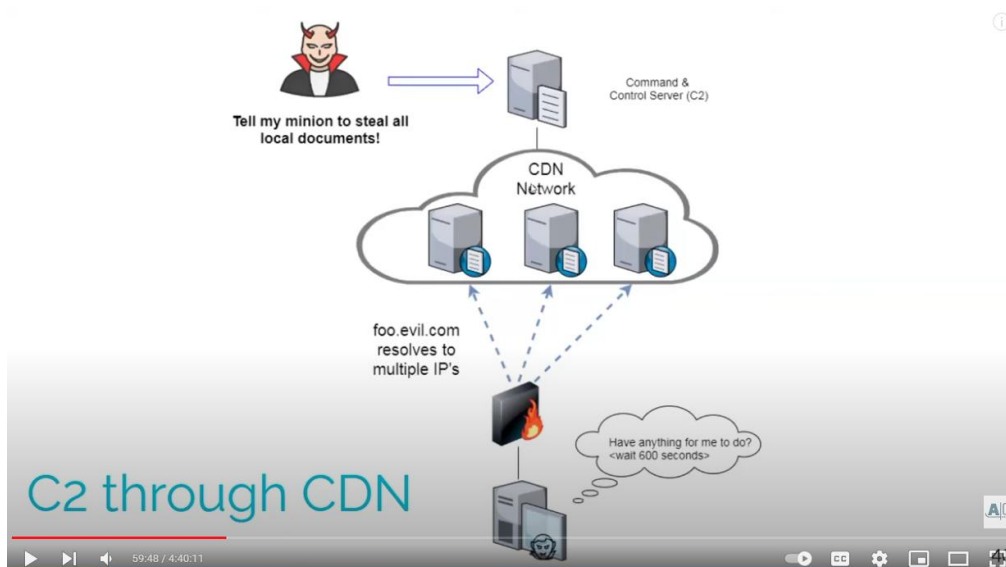
Inspectons maintenant la partie Beacons Web :

Lorsque nous utilisons SiteReview pour l'historique de FQDN du destinataire de nos fameuses beacon connexions de notre adresse IP, nous avons quelques indicateurs que le site web est compromis.



Qu'est-ce que cela veut dire? C'est probablement ce que les attaquants utilisent comme centre de commande et de contrôle (C2).

Explication : Les attaquants utilisent le site compromis comme serveur de commande et de contrôle (C2). Cela permet aux attaquants de communiquer avec les systèmes compromis en utilisant un domaine apparemment légitime pour dissimuler leur activité.



Tel que mentionné dans le vidéo, un autre indicateur louche pourrait être le queried FQDN à *no results*.
Maintenant pour l'indicateur "strokes", voici l'analyse :

General Information

Hostnames	wp.chungassistant.com www.wp.chungassistant.com
Domains	CHUNGASSISTANT.COM
Cloud Provider	DigitalOcean
Cloud Region	us-nj
Country	United States
City	North Bergen
Organization	DigitalOcean, LLC
ISP	DigitalOcean, LLC
ASN	AS14061

Web Technologies

Mindblown: a blog about philosophy.

Hello world!

Welcome to WordPress. This is your first post. Edit or delete it, then start writing!
 May 1, 2023

Got any book recommendations?

[Select a book](#)

IP Source (Src IP) : 192.168.88.2

Nom du Réseau Source (Src Network Name) : Carol

IP Destination (Dst IP) : 165.227.88.15

Nom du Réseau Destination (Dst Network Name) : Public

Nombre de Connexions (Connection Count) : 108858

Nom de Domaine Entièrement Qualifié de Destination (Dst FQDN) : badddns.r-1x.com

Analyse :

IP Source (192.168.88.2) :

Il s'agit d'une adresse IP privée (RFC 1918), généralement utilisée pour les adresses réseau internes. Cela ne donne pas beaucoup d'informations sur la nature de la menace en soi.

IP Destination (165.227.88.15) :

Il s'agit d'une adresse IP publique. Pour obtenir plus d'informations, il serait nécessaire de réaliser une recherche WHOIS ou de consulter des sources de renseignement sur les menaces.

Nom de Domaine Entièrement Qualifié de Destination (badddns.r-1x.com) :

Le nom de domaine "badddns.r-1x.com" est très suspect. Le préfixe "bad" suggère qu'il pourrait être utilisé à des fins malveillantes. De plus, "ddns" se réfère au DNS dynamique, souvent utilisé par les cybercriminels pour éviter la détection en changeant dynamiquement les adresses IP associées au domaine.

Nombre de Connexions (108858) :

Le nombre très élevé de connexions indique une quantité anormalement grande de trafic entre la source et la destination. Cela pourrait suggérer que la machine source est infectée par un logiciel malveillant et communique fréquemment avec le serveur de commande et de contrôle hébergé à la destination.

Indicateurs Suspects :

Nombre Élevé de Connexions : Le nombre élevé de connexions est anormal et suggère une activité potentiellement malveillante.

Nom de Domaine Suspect : Le domaine "badddns.r-1x.com" est un fort indicateur d'activité malveillante.

Pour la section "long connections" :

Source (Src) et Destination (Dst) :

Toutes les adresses IP source appartiennent à la même plage (10.55.100.x), ce qui indique qu'elles proviennent du même réseau interne nommé "Carol".

Les adresses IP de destination sont toutes des adresses publiques.

Protocole et Port :

Le protocole utilisé est principalement TCP avec le port 443, ce qui est typique pour HTTPS.

Durée et Taille des Données :

Les connexions ont des durées longues, allant de 15 heures à presque 24 heures, ce qui est inhabituel pour des connexions HTTPS standards.

Le volume de données transférées est relativement faible comparé à la durée de la connexion.
Comportements Suspects?

Connexions Longues et Stables :

Les connexions HTTPS (port 443) avec des durées proches de 24 heures sont suspectes. Les connexions HTTPS légitimes pour des sessions utilisateur normales ne durent généralement pas aussi longtemps.

Volume de Données Transférées :

Le volume de données transférées est faible par rapport à la durée des connexions. Cela pourrait indiquer une connexion de commande et contrôle (C2) où les échanges de données sont intermittents mais la connexion reste ouverte pour recevoir des instructions.

Adresse IP de Destination :

L'adresse IP de destination 65.52.108.225 est marquée comme "Microsoft Corp." Cela pourrait être légitime, mais il vaut la peine de vérifier si ce trafic est attendu pour vos systèmes.

D'autres adresses IP de destination peuvent être vérifiées pour déterminer si elles appartiennent à des services légitimes ou si elles sont associées à des activités malveillantes.

Vérifications Recommandées

Analyse de la Destination :

Vérifiez les adresses IP de destination pour déterminer si elles appartiennent à des services connus et attendus dans votre environnement. Et évidemment, lorsqu'on regarde avec SiteReview le site de saint church par exemple, nous avons des indicateurs de URL malveillants.

Inspection des Connexions :

Les connexions HTTPS de longue durée avec peu de transfert de données peuvent indiquer que des malwares sont en communication avec leurs serveurs de C2.

Surveillance Continue :

Configurez des alertes pour les connexions HTTPS de longue durée et pour des volumes de données anormalement faibles par rapport à la durée de la connexion.

Effectuez une analyse approfondie des hôtes source pour détecter des malwares ou des infections.

Conclusion

Les connexions longues et stables avec un faible volume de données sur le port 443 dans AC Hunter peuvent indiquer des activités malveillantes, notamment des connexions de commande et contrôle (C2). Il est crucial de vérifier les adresses IP de destination et de surveiller attentivement ces connexions.

Pour la section "threat intel" :

Pas mal les mêmes infos que l'indicateur précédent sont présent ici. Nous pouvons voir la même adresse de destination et ses différents bytes transférés, nombre total de connexion, l'utilisation inhabituelle des Ports DNS intensive et du port 53 pour des connexions TCP est suspecte.

Maintenant, utilisons l'outil deep dive pour notre fameuse adresse IP compromise (10.55.100.111). Nous pouvons voir ci-dessous, toutes les adresse et query que cette adresse fait, ce qui faciliterait l'analyse.

